

Detección y prevención de acciones maliciosas en agentes de inteligencia artificial

Autor:
Ing. Esp. Florencia Priscilla Vela

Director:
Ms. Abraham Adolfo Rodriguez Zepeda (FIUBA)

Esta planificación fue realizada en el curso de Gestión de proyectos entre el 19 de octubre de 2026 y el 7 de diciembre de 2026.

Índice

1. Descripción técnica-conceptual del proyecto a realizar **5**

2. Identificación y análisis de los interesados **7**

3. Propósito del proyecto **8**

4. Alcance del proyecto **8**

5. Supuestos del proyecto **9**

6. Requerimientos **9**

7. Historias de usuarios (*Product backlog*) **10**

8. Entregables principales del proyecto **11**

9. Desglose del trabajo en tareas **11**

10. Diagrama de Activity On Node **12**

11. Diagrama de Gantt **12**

12. Presupuesto detallado del proyecto **16**

13. Gestión de riesgos **16**

14. Gestión de la calidad **17**

15. Procesos de cierre **18**

Registros de cambios

Revisión	Detalles de los cambios realizados	Fecha
0	Creación del documento	19 de octubre de 2026
1	Se completa hasta el punto 6 inclusive	29 de octubre de 2026

Acta de constitución del proyecto

Buenos Aires, 19 de octubre de 2026

Por medio de la presente se acuerda con el Ing. Esp. Florencia Priscilla Vela que su Trabajo Final de la Maestría en Inteligencia Artificial se titulará "Detección y prevención de acciones maliciosas en agentes de inteligencia artificial" y consistirá en el desarrollo de un sistema que evalúa cada acción propuesta por un agente de IA antes de ejecutarla y decide si permitirla, revisarla o bloquearla según su riesgo. El trabajo tendrá un presupuesto preliminar estimado de 600 horas y un costo estimado de $ XXX, con fecha de inicio el 19 de octubre de 2026 y fecha de presentación pública el 15 de noviembre de 2027.

Se adjunta a esta acta la planificación inicial.

Dr. Ing. Ariel Lutenberg Director posgrado FIUBA	Nombre del cliente Empresa del cliente

Ms. Abraham Adolfo Rodriguez Zepeda
Director del Trabajo Final

1. Descripción técnica-conceptual del proyecto a realizar

Los modelos de lenguaje de gran escala (en inglés, *Large Language Models* o LLM) se popularizaron como sistemas conversacionales capaces de recibir y producir texto. Sobre esta base surgieron los agentes de inteligencia artificial (IA), que incorporan la capacidad de planificar y ejecutar tareas mediante herramientas. Así, además de responder consultas, un agente puede leer y modificar archivos, ejecutar comandos, enviar correos o utilizar servicios externos. Esta capacidad de acción los vuelve útiles, pero también les permite acceder a recursos sensibles y genera nuevos riesgos de seguridad.

Uno de estos riesgos aparece cuando un agente consulta una página web o un documento que contiene instrucciones maliciosas. El agente puede interpretar esas instrucciones como parte del pedido original y actuar en consecuencia. Este tipo de ataque, conocido como *prompt injection* o inyección de instrucciones, podría llevarlo a divulgar información sensible, enviar datos a destinos no autorizados, modificar o borrar recursos sin permiso, ejecutar código no aprobado o intentar ampliar sus privilegios. El momento de la detección es fundamental, ya que si el desvío se identifica después de ejecutar la acción, el daño puede ser difícil o imposible de revertir. Por eso, resulta necesario contar con controles que evalúen las acciones antes de que se ejecuten.

En este contexto, el proyecto propone desarrollar un componente de control que actúe como intermediario entre el agente y sus herramientas. Su función es evaluar cada acción propuesta y decidir si corresponde permitirla, enviarla a revisión o bloquearla antes de su ejecución. Se trata de una iniciativa académica individual, realizada en el marco del Trabajo Final de la Maestría en Inteligencia Artificial, dirigida a personas u organizaciones que utilizan agentes para trabajar con datos, archivos o servicios y necesitan delegar tareas sin exponer recursos sensibles. Para estos usuarios, resultan especialmente relevantes la preservación de la privacidad y la precisión de las alertas, de manera que el sistema detecte acciones riesgosas sin interrumpir innecesariamente las tareas legítimas.

Para tomar cada decisión, el sistema considera tres fuentes de información: los permisos del agente, la herramienta que pretende utilizar junto con sus argumentos y el contexto reciente de la sesión. La evaluación combina el grado en que una acción se aparta del comportamiento esperado con su coherencia respecto del objetivo de la tarea y los permisos otorgados. Se busca que el control funcione en tiempo real, con baja latencia, y que pueda ejecutarse de manera local y liviana en la máquina del usuario para preservar la privacidad. También se contempla su adaptación a los recursos disponibles, mediante la selección de modelos según la capacidad de cómputo y la memoria del equipo.

El funcionamiento de la solución se presenta en la figura 1. Cuando el agente propone una acción, el componente de control aplica primero un conjunto de reglas explícitas de permisos que no dependen de la IA. Por ejemplo, una regla puede impedir que un agente con determinado rol lea un archivo de credenciales. Si estas reglas no son suficientes para resolver la decisión, un modelo de riesgo evalúa la acción a partir del contexto de la sesión. La decisión final integra ambos mecanismos: solo las acciones clasificadas como permitidas llegan al ejecutor; las que requieren revisión quedan pendientes y las bloqueadas no se ejecutan. Las restricciones establecidas por las reglas mantienen su validez independientemente de la puntuación del modelo, de modo que este no puede anular una prohibición explícita.

En cuanto al estado del arte, se identifican distintas líneas de trabajo relacionadas con el problema. Una de ellas comprende modelos de protección como Llama Guard, ShieldGemma y Granite Guardian, que permiten detectar riesgos en las entradas y respuestas de los modelos de lenguaje. Otra incluye modelos orientados a producir decisiones estructuradas a partir de un

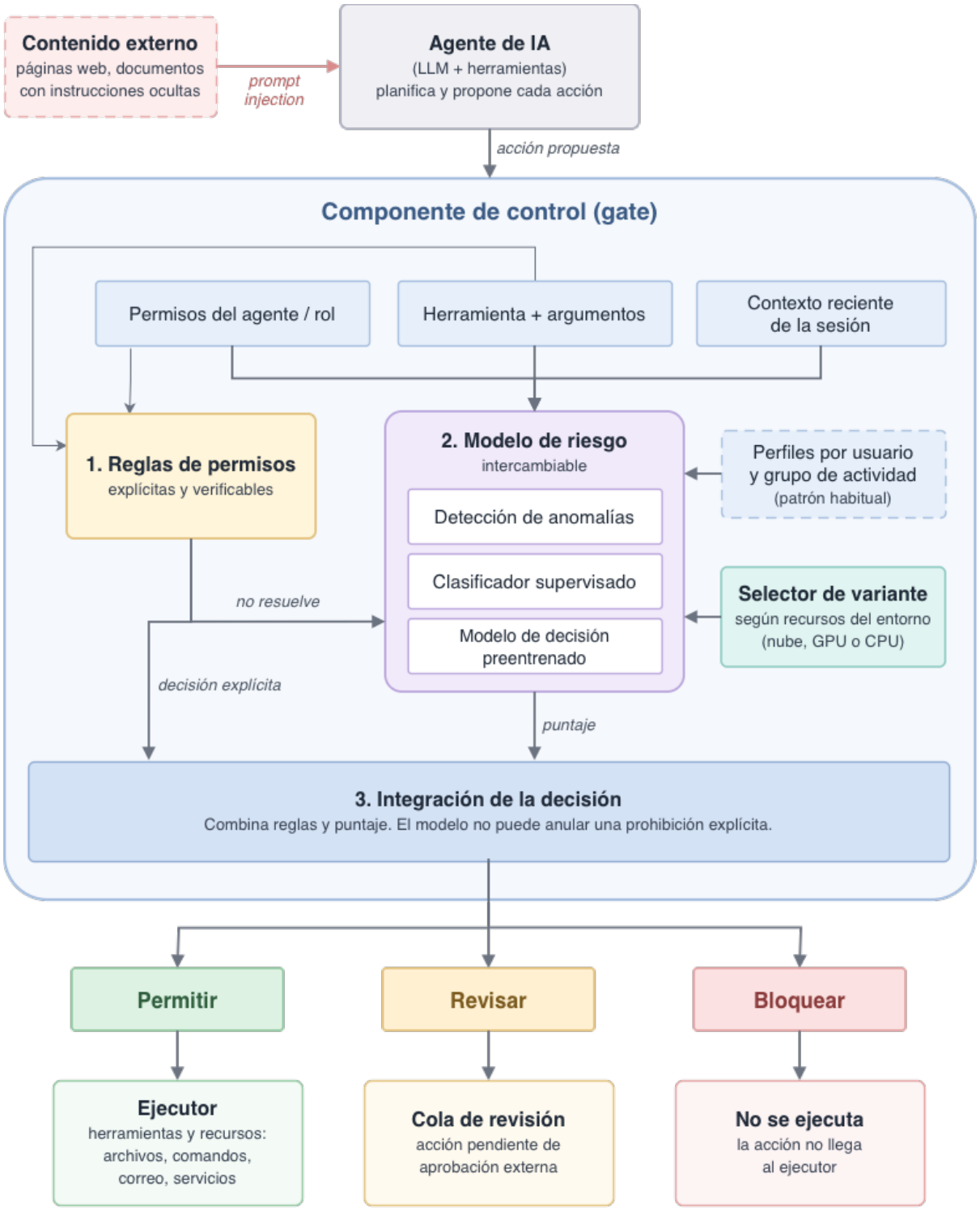


Figura 1. Diagrama en bloques del sistema.

contexto y una pregunta, como Jev y Laya. Estos modelos pueden devolver una categoría, una puntuación o una probabilidad, por lo que constituyen alternativas para explorar en la evaluación de acciones. También existen mecanismos de control sobre el uso de herramientas, como Invariant Guardrails y Progent, y sistemas de protección para agentes, como LlamaFirewall. A estas líneas se suman las técnicas de detección de anomalías de comportamiento, que permiten identificar desviaciones respecto de patrones habituales.

Además, se busca que el sistema pueda adaptarse a equipos de bajos recursos. Para ello se explorarán variantes cuantizadas, que reducen los requisitos de memoria y facilitan el uso de modelos en máquinas de capacidad limitada. La propuesta combina reglas verificables con una evaluación contextual del riesgo, y su utilidad deberá analizarse en comparación con los enfoques existentes, considerando tanto la detección de acciones riesgosas como la latencia y el consumo de recursos.

Una de las etapas más importantes será definir el conjunto de datos sobre el cual se realizarán las pruebas, ya que caracterizar un comportamiento como malicioso constituye un problema complejo. Una misma acción puede ser legítima o riesgosa según el objetivo de la tarea, los permisos otorgados, los recursos involucrados y el contexto en el que se propone. Además, una acción poco habitual no necesariamente es maliciosa, y una acción frecuente puede resultar perjudicial si se realiza sin autorización.

Por este motivo, la construcción del conjunto de datos requerirá establecer criterios claros para distinguir acciones permitidas, acciones que requieren revisión y acciones que deben bloquearse. Se prevé considerar datos públicos y ejemplos sintéticos que representen tanto tareas legítimas como intentos de desvío y situaciones ambiguas. Sobre esta base se compararán detectores de anomalías, clasificadores supervisados y modelos de decisión preentrenados, con el objetivo de identificar qué enfoques ofrecen el equilibrio más adecuado entre detección de riesgos, precisión de las alertas y requisitos de ejecución.

2. Identificación y análisis de los interesados

En la tabla 1 se identifican los interesados del proyecto. Al tratarse de un Trabajo Final de carácter académico e individual, varios roles habituales en proyectos mayores (auspiciante, impulsor, colaboradores, equipo, opositores) no aplican y se omiten.

Cuadro 1. Identificación de los interesados.

Rol	Nombre y Apellido	Organización	Puesto
Cliente	Cátedra de Trabajo Final	FIUBA	Validador académico
Responsable	Ing. Esp. Florencia Priscilla Vela	FIUBA	Alumna
Orientador	Ms. Abraham Adolfo Rodriguez Zepeda	FIUBA	Director del Trabajo Final
Usuario final	Personas y equipos técnicos que utilizan agentes de IA	-	Desarrolladores, analistas y perfiles de finanzas, RR. HH. e IT

A continuación se describen las principales características de cada interesado:

- **Cliente:** la cátedra actúa como validadora académica del trabajo; aprueba los resultados y verifica que se cumplan los objetivos comprometidos en el acta.

- **Responsable:** ejecuta la totalidad del trabajo técnico y la redacción de la memoria. Su disponibilidad es de tipo *part-time*, lo que condiciona el cronograma y obliga a planificar con holgura.
- **Orientador:** el Director del Trabajo Final es experto en la temática y colabora en la definición de los requerimientos, la metodología de evaluación y la revisión de la memoria.
- **Usuario final:** valora la privacidad (que sus datos no salgan de su equipo), un bajo impacto en la fluidez de uso (pocas falsas alarmas) y que la solución funcione en computadoras de capacidad modesta.

3. Propósito del proyecto

Evaluar y construir un sistema capaz de detectar y frenar acciones maliciosas de agentes de inteligencia artificial en el instante previo a su ejecución. Se busca que el sistema funcione de forma liviana y local para preservar la privacidad del usuario. También se propone entregar evidencia reproducible sobre qué enfoques ofrecen el mejor equilibrio entre seguridad (detectar ataques), usabilidad (pocas falsas alarmas) y costo computacional (latencia, memoria y tamaño). Estos enfoques incluyen la detección de anomalías, los clasificadores entrenados, los modelos de decisión preentrenados y sus combinaciones. Además, se contemplarán versiones adaptadas a distintos niveles de recursos del equipo del usuario.

4. Alcance del proyecto

El proyecto incluye:

- Revisión del estado del arte y preparación de los datos: conjuntos públicos ya identificados y un conjunto sintético propio controlado.
- Implementación de tres familias de detectores y de su combinación:
  - detección de anomalías, que identifica lo que se aparta de lo normal sin requerir ejemplos de ataques;
  - clasificadores entrenados, que aprenden de ejemplos etiquetados a distinguir una acción riesgosa de una legítima;
  - modelos de decisión preentrenados, es decir, modelos pequeños y rápidos que eligen entre opciones.
- Un banco de pruebas (*benchmark*) reproducible que mida, para cada enfoque: cuántos ataques detecta antes de ejecutarse, cuántas falsas alarmas genera (por acción y por sesión), la latencia, la memoria RAM, el tamaño del modelo y el uso de cómputo.
- Técnicas de optimización: cuantización (compresión) y comparación de versiones del mismo modelo en distintas precisiones, para hacerlo viable en equipos modestos.
- Un intermediario configurable (el *gate*) que se interpone entre el agente y sus herramientas, con una matriz de decisión que elige la mejor variante según el entorno (nube autorizada, GPU local, o poca memoria RAM, caso en el que se usa la versión liviana).
- La memoria del Trabajo Final, el código fuente documentado y los resultados reproducibles.

El proyecto no incluye:

- Un producto comercial listo para producción.
- El entrenamiento de modelos de lenguaje grandes desde cero; se parte de modelos existentes.
- La integración con un *sandbox* de agentes; esto quedaría como trabajo futuro o prueba exploratoria.
- La recolección de datos reales de usuarios; se trabaja con datos públicos y sintéticos, por lo que los resultados no se reportan como incidentes reales confirmados.

5. Supuestos del proyecto

Para el desarrollo del proyecto se supone que:

- Se dispone de datos públicos útiles para construir modelos de detección de comportamiento malicioso.
- Se dispone de acceso a modelos abiertos en repositorios como Hugging Face y GitHub.
- Se cuenta con acceso a cómputo con GPU de forma gratuita o de bajo costo (por ejemplo, Google Colab) para las partes que lo requieran; el resto corre en una computadora personal.
- La disponibilidad horaria de la responsable permite sostener las 600 h estimadas, distribuidas en el período de ejecución (modalidad *part-time*), con la orientación periódica del director.
- Las licencias de los modelos y conjuntos de datos de terceros permiten su uso con fines académicos y de investigación.
- La disponibilidad de los servicios de cómputo y el acceso a internet se mantienen razonablemente estables durante el proyecto.
- Los resultados se evalúan sobre datos sintéticos o de laboratorio; se asume que esto es suficiente para comparar enfoques entre sí, aunque no para afirmar su eficacia en un entorno de producción real.

6. Requerimientos

Los requerimientos se agrupan por afinidad.

1. Requerimientos funcionales:
   1.1. El sistema debe evaluar cada acción propuesta por el agente antes de ejecutarla y devolver una de tres decisiones: permitir, revisar o bloquear.
   1.2. El sistema debe usar como entrada únicamente información disponible antes de la acción (contexto de la sesión, herramienta, argumentos y permisos); no debe usar información del futuro ni las etiquetas.

1.3. El sistema debe aplicar reglas de permisos verificables, independientes del modelo de IA (por ejemplo, denegar la lectura de archivos de credenciales).

1.4. El sistema debe permitir intercambiar el modelo de riesgo (anomalías, clasificador o decisión preentrenada) sin modificar el resto del sistema.

1.5. El sistema debe soportar perfiles por usuario y por grupo de actividad, y marcar los desvíos respecto del patrón habitual.

1.6. El sistema debe elegir automáticamente la variante de modelo según los recursos del entorno (nube, GPU o CPU con poca memoria RAM).

2. Requerimientos de desempeño:

2.1. El sistema debe tomar cada decisión rápidamente; en la variante liviana corriendo en CPU, cada decisión debe tardar en promedio como mucho 500 ms.

2.2. El sistema debe poder funcionar usando como mucho 2 GB de memoria RAM adicional.

2.3. El sistema debe ocupar como máximo 1 GB en disco.

3. Requerimientos de seguridad y privacidad:

3.1. La inferencia debe poder ejecutarse 100 % de forma local, sin enviar datos a internet.

3.2. El uso de la nube debe ser opcional y explícitamente autorizado por el usuario.

4. Requerimientos de documentación:

4.1. Memoria del Trabajo Final.

4.2. Documentación que permita reproducir los experimentos con los conjuntos de datos públicos.

4.3. Documentación de los conjuntos de datos, con su origen y sus códigos de verificación de integridad (en inglés, *checksums*).

5. Requerimientos de testing:

5.1. Pruebas automatizadas del *gate*.

6. Requerimientos de interoperabilidad:

6.1. Interfaz simple que reciba el contexto y la acción propuesta y devuelva la decisión, para integrarse con distintas plataformas anfitrionas, incluido un *sandbox* de agentes.

7. Requerimientos regulatorios y de normas:

7.1. Cumplir con la normativa de protección de datos personales aplicable (en Argentina, la Ley 25.326; se consideran además principios del GDPR por buenas prácticas), dado que el sistema observa el comportamiento de los usuarios: minimización de datos, procesamiento local y anonimización cuando corresponda.

7.2. Respetar las licencias de los conjuntos de datos y modelos de terceros.

7. Historias de usuarios (*Product backlog*)

Descripción: en esta sección se deben incluir las historias de usuarios y su ponderación (*history points*). Recordar que las historias de usuarios son descripciones cortas y simples de una característica contada desde la perspectiva de la persona que desea la nueva capacidad,

generalmente un usuario o cliente del sistema. La ponderación es un número entero que representa el tamaño de la historia comparada con otras historias de similar tipo.

Se debe indicar explícitamente el criterio para calcular los *story points* de cada historia.

El formato propuesto es:

1. "Como [rol] quiero [tal cosa] para [tal otra cosa]."
   Story points: 8 (complejidad: 3, dificultad: 2, incertidumbre: 3)

8. Entregables principales del proyecto

Los entregables del proyecto son (ejemplo):

- Manual de usuario.
- Diagrama de circuitos esquemáticos.
- Código fuente del firmware.
- Diagrama de instalación.
- Memoria del trabajo final.
- etc...

9. Desglose del trabajo en tareas

El WBS debe tener relación directa o indirecta con los requerimientos. Son todas las actividades que se harán en el proyecto para dar cumplimiento a los requerimientos. Se recomienda mostrar el WBS mediante una lista indexada:

1. Grupo de tareas 1 (suma h)
   1.1. Tarea 1 (tantas h)
   1.2. Tarea 2 (tantas h)
   1.3. Tarea 3 (tantas h)
2. Grupo de tareas 2 (suma h)
   2.1. Tarea 1 (tantas h)
   2.2. Tarea 2 (tantas h)
   2.3. Tarea 3 (tantas h)
3. Grupo de tareas 3 (suma h)
   3.1. Tarea 1 (tantas h)

3.2. Tarea 2 (tantas h)
3.3. Tarea 3 (tantas h)
3.4. Tarea 4 (tantas h)
3.5. Tarea 5 (tantas h)

Cantidad total de horas: tantas.

¡Importante!: la unidad de horas es h y va separada por espacio del número. Es incorrecto escribir "23hs".

Se recomienda que no haya ninguna tarea que lleve más de 40 h. De ser así se recomienda dividirla en tareas de menor duración.

10. Diagrama de Activity On Node

Armar el AoN a partir del WBS definido en la etapa anterior.

Una herramienta simple para desarrollar los diagramas es el Draw.io (`https://app.diagrams.net/`). Draw.io

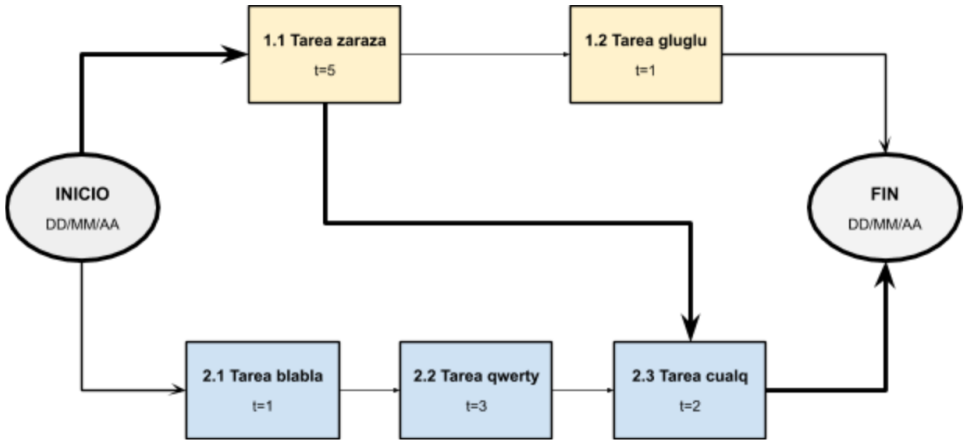


Figura 2. Diagrama de *Activity on Node*.

Indicar claramente en qué unidades están expresados los tiempos. De ser necesario indicar los caminos semi críticos y analizar sus tiempos mediante un cuadro. Es recomendable usar colores y un cuadro indicativo describiendo qué representa cada color.

11. Diagrama de Gantt

Existen muchos programas y recursos *online* para hacer diagramas de Gantt, entre los cuales destacamos:

- Planner
- GanttProject

- Trello + *plugins*. En el siguiente link hay un tutorial oficial:
  https://blog.trello.com/es/diagrama-de-gantt-de-un-proyecto
- Creately, herramienta online colaborativa.
  https://creately.com/diagram/example/ieb3p3ml/LaTeX
- Se puede hacer en latex con el paquete *pgfgantt*
  http://ctan.dcc.uchile.cl/graphics/pgf/contrib/pgfgantt/pgfgantt.pdf

Pegar acá una captura de pantalla del diagrama de Gantt, cuidando que la letra sea suficientemente grande como para ser legible. Si el diagrama queda demasiado ancho, se puede pegar primero la "tabla" del Gantt y luego pegar la parte del diagrama de barras del diagrama de Gantt.

Configurar el software para que en la parte de la tabla muestre los códigos del EDT (WBS).
Configurar el software para que al lado de cada barra muestre el nombre de cada tarea.
Revisar que la fecha de finalización coincida con lo indicado en el Acta Constitutiva.

En la figura 3, se muestra un ejemplo de diagrama de gantt realizado con el paquete de *pgfgantt*. En la plantilla pueden ver el código que lo genera y usarlo de base para construir el propio.

Las fechas pueden ser calculadas utilizando alguna de las herramientas antes citadas. Sin embargo, el siguiente ejemplo fue elaborado utilizando esta hoja de cálculo.

Es importante destacar que el ancho del diagrama estará dado por la longitud del texto utilizado para las tareas (Ejemplo: tarea 1, tarea 2, etcétera) y el valor *x unit*. Para mejorar la apariencia del diagrama, es necesario ajustar este valor y, quizás, acortar los nombres de las tareas.

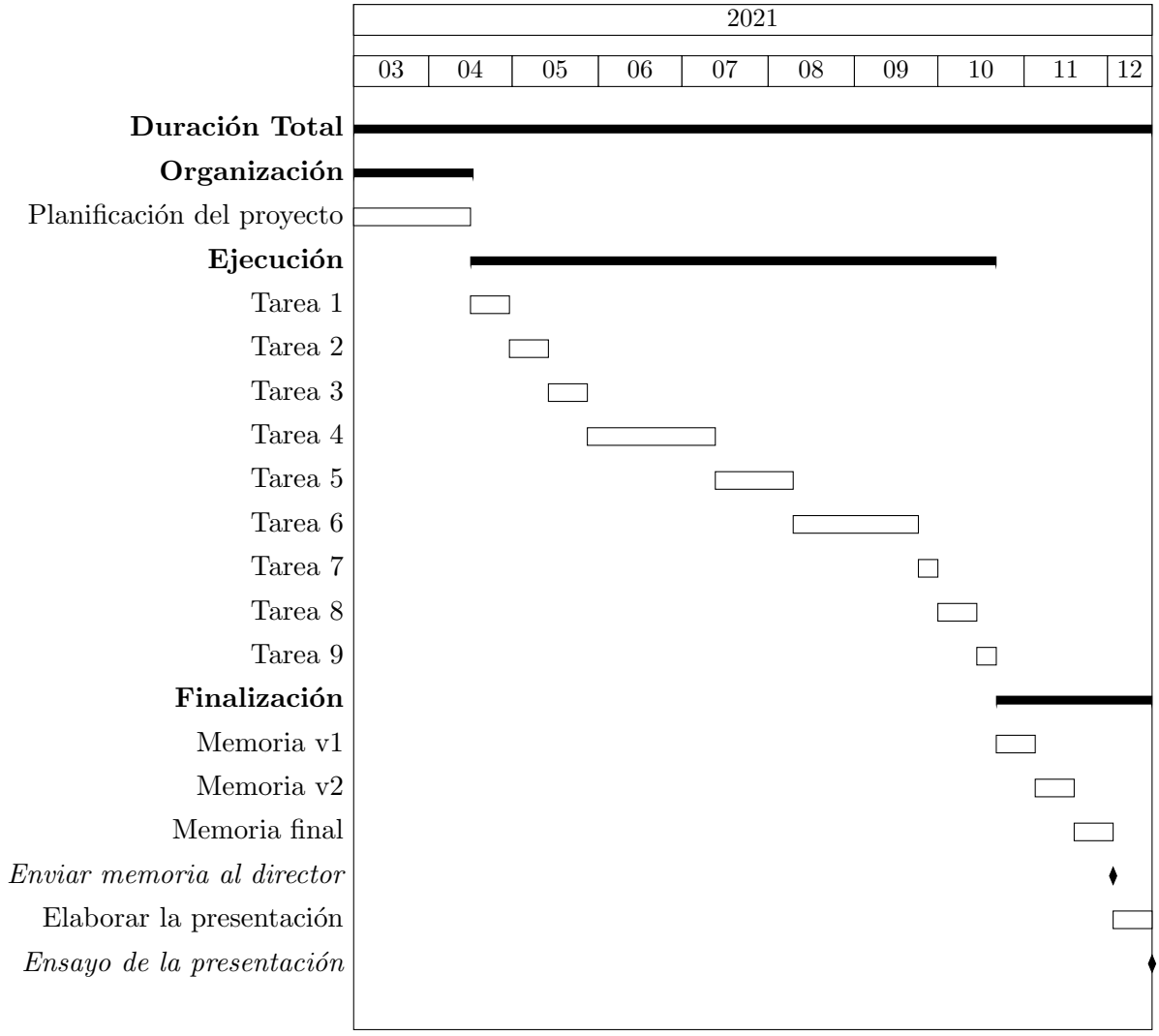


Figura 3. Diagrama de gantt de ejemplo

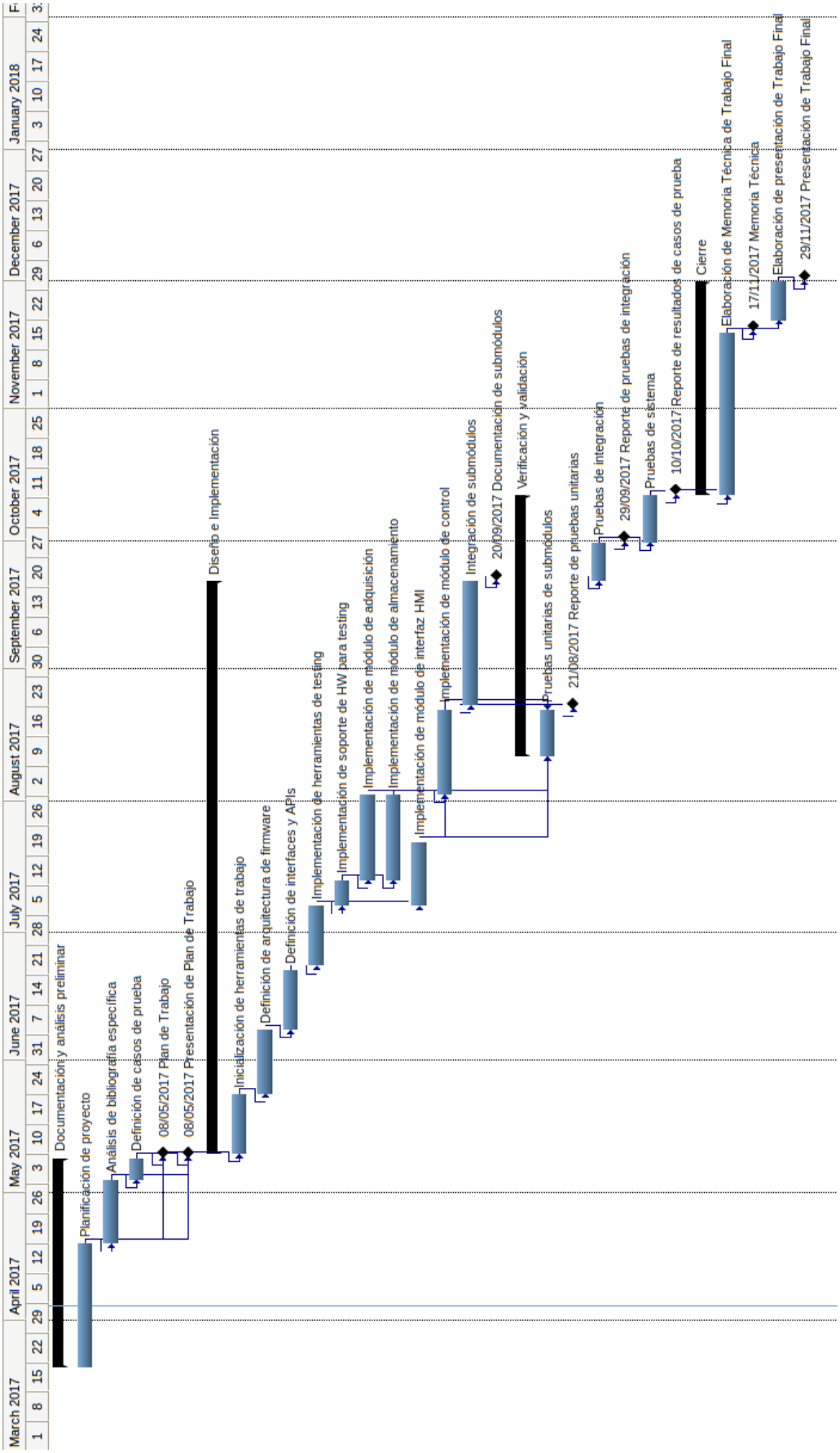


Figura 4. Ejemplo de diagrama de Gantt (apaisado).

12. Presupuesto detallado del proyecto

Si el proyecto es complejo entonces separarlo en partes:

- Un total global, indicando el subtotal acumulado por cada una de las áreas.
- El desglose detallado del subtotal de cada una de las áreas.

IMPORTANTE: No olvidarse de considerar los COSTOS INDIRECTOS.

Incluir la aclaración de si se emplea como moneda el peso argentino (ARS) o si se usa moneda extranjera (USD, EUR, etc). Si es en moneda extranjera se debe indicar la tasa de conversión respecto a la moneda local en una fecha dada.

COSTOS DIRECTOS			
Descripción	Cantidad	Valor unitario	Valor total
SUBTOTAL			
COSTOS INDIRECTOS			
Descripción	Cantidad	Valor unitario	Valor total
SUBTOTAL			
TOTAL			

13. Gestión de riesgos

a) Identificación de los riesgos (al menos cinco) y estimación de sus consecuencias:

Riesgo 1: detallar el riesgo (riesgo es algo que si ocurre altera los planes previstos de forma negativa)

- Severidad (S): mientras más severo, más alto es el número (usar números del 1 al 10).
  Justificar el motivo por el cual se asigna determinado número de severidad (S).
- Probabilidad de ocurrencia (O): mientras más probable, más alto es el número (usar del 1 al 10).
  Justificar el motivo por el cual se asigna determinado número de (O).

Riesgo 2:

- Severidad (S): X.
  Justificación...

- Ocurrencia (O): Y.
  Justificación...

Riesgo 3:

- Severidad (S): X.
  Justificación...
- Ocurrencia (O): Y.
  Justificación...

b) Tabla de gestión de riesgos: (El RPN se calcula como RPN=SxO)

Riesgo	S	O	RPN	S*	O*	RPN*

Criterio adoptado:

Se tomarán medidas de mitigación en los riesgos cuyos números de RPN sean mayores a...

Nota: los valores marcados con (*) en la tabla corresponden luego de haber aplicado la mitigación.

c) Plan de mitigación de los riesgos que originalmente excedían el RPN máximo establecido:

Riesgo 1: plan de mitigación (si por el RPN fuera necesario elaborar un plan de mitigación). Nueva asignación de S y O, con su respectiva justificación:

- Severidad (S*): mientras más severo, más alto es el número (usar números del 1 al 10). Justificar el motivo por el cual se asigna determinado número de severidad (S).
- Probabilidad de ocurrencia (O*): mientras más probable, más alto es el número (usar del 1 al 10). Justificar el motivo por el cual se asigna determinado número de (O).

Riesgo 2: plan de mitigación (si por el RPN fuera necesario elaborar un plan de mitigación).

Riesgo 3: plan de mitigación (si por el RPN fuera necesario elaborar un plan de mitigación).

14. Gestión de la calidad

Elija al menos diez requerimientos que a su criterio sean los más importantes/críticos/que aportan más valor y para cada uno de ellos indique las acciones de verificación y validación que permitan asegurar su cumplimiento.

- Req #1: copiar acá el requerimiento con su correspondiente número.

- Verificación para confirmar si se cumplió con lo requerido antes de mostrar el sistema al cliente. Detallar.
- Validación con el cliente para confirmar que está de acuerdo en que se cumplió con lo requerido. Detallar.

Tener en cuenta que en este contexto se pueden mencionar simulaciones, cálculos, revisión de hojas de datos, consulta con expertos, mediciones, etc.

Las acciones de verificación suelen considerar al entregable como "caja blanca", es decir se conoce en profundidad su funcionamiento interno.

En cambio, las acciones de validación suelen considerar al entregable como "caja negra", es decir, que no se conocen los detalles de su funcionamiento interno.

15. Procesos de cierre

Establecer las pautas de trabajo para realizar una reunión final de evaluación del proyecto, tal que contemple las siguientes actividades:

- Pautas de trabajo que se seguirán para analizar si se respetó el Plan de Proyecto original:
  - Indicar quién se ocupará de hacer esto y cuál será el procedimiento a aplicar.
- Identificación de las técnicas y procedimientos útiles e inútiles que se emplearon, los problemas que surgieron y cómo se solucionaron:
  - Indicar quién se ocupará de hacer esto y cuál será el procedimiento para dejar registro.
- Indicar quién organizará el acto de agradecimiento a todos los interesados, y en especial al equipo de trabajo y colaboradores:
  - Indicar esto y quién financiará los gastos correspondientes.